

# CSE 717 — Information Security

## Topic 2: Security Fundamentals & Attack Vectors

### Complete Past Paper Solutions: 2020–2024

Source: *LcMaterial#1\_InfoSecuritySP26.pdf* pp.2–17 (attack vectors) + general security knowledge (no-source cheat sheet)

**Every Topic-2 question 2020–2024 included. Zero omissions.**

## Contents

---

|          |                                                                                                                                                |           |
|----------|------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>1</b> | <b>2024 — Q1(a,b): Symmetric vs Asymmetric Crypto + Handshaking/Digest (5 marks)</b>                                                           | <b>4</b>  |
| 1.1      | Part (a): Symmetric vs Asymmetric Cryptography . . . . .                                                                                       | 4         |
| 1.2      | Part (b): Handshaking and Message Digest . . . . .                                                                                             | 4         |
| <b>2</b> | <b>2023 — Q2(b,c): Digital Certificates/CA/SSL + Securing a Network from 4 Attack Types (6 marks)</b>                                          | <b>6</b>  |
| 2.1      | Part (b): Digital Certificates, Certificate Authorities, and SSL . . . . .                                                                     | 6         |
| 2.2      | Part (c): Securing a Network from 4 Attack Types . . . . .                                                                                     | 7         |
| 2.3      | Related (Q4(c)): Shannon’s Two Atomic Operations . . . . .                                                                                     | 7         |
| <b>3</b> | <b>2022 — Q1 (8 marks): Security Vocabulary; Q7(b,c): SQLi/Social Eng + SWIFT</b>                                                              | <b>8</b>  |
| 3.1      | Part (a): “Ambiguity is Security” — Why and How? . . . . .                                                                                     | 8         |
| 3.2      | Part (b): Fill-in-the-Blank — Threat Actor Terminology . . . . .                                                                               | 8         |
| 3.3      | Part (c): Security Professions — Roles and Responsibilities . . . . .                                                                          | 9         |
| 3.4      | Part (d): Steganography . . . . .                                                                                                              | 10        |
| 3.5      | Part Q7(b): SQL Injection and Social Engineering — Short Notes . . . . .                                                                       | 10        |
| 3.6      | Part Q7(c): SWIFT Banking Network Pentest Scenario . . . . .                                                                                   | 10        |
| <b>4</b> | <b>2021 — A-1: Risk Equation, Biometrics, Wireless (8.75 marks); B-4(a,d): Ransomware/Social Eng + Backdoor/Logic Bomb/Trojan (3.75 marks)</b> | <b>12</b> |
| 4.1      | Part A-1(a): Risk Equation and Model . . . . .                                                                                                 | 12        |
| 4.2      | Part A-1(b): Biometric Authentication — Failure Modes and Evaluation . . . . .                                                                 | 12        |
| 4.3      | Part A-1(c): Threats in Wireless Security . . . . .                                                                                            | 13        |
| 4.4      | Part B-4(a): Ransomware vs Social Engineering . . . . .                                                                                        | 13        |
| 4.5      | Part B-4(d): Backdoor, Logic Bomb, Trojan Horse . . . . .                                                                                      | 14        |

## Quick Reference — Definitions Cheat Sheet

### Covered by Lc#1 pp.2–17 — Attack-Vector Short Notes

- **Rogue security software:** fake malware-alert pop-ups that trick users into installing real malware or paying for a fake "fix".
- **DoS (Denial of Service):** one machine floods a server with traffic so it can't serve legitimate users.
- **DDoS (Distributed DoS):** same goal as DoS but launched from many compromised machines (a **botnet**) across many IPs — much harder to block or trace.
- **Phishing:** a **social-engineering** technique — fake emails/messages trick victims into revealing credentials or installing malware.
- **SQL Injection:** malicious SQL via input fields exploits app vulnerabilities to read/modify/destroy DB data or bypass authentication.
- **Ransomware (Clop / WannaCry):** malware that encrypts files/whole networks and demands payment; Clop first disables Windows Defender/Security Essentials, then spreads network-wide.

### NOT in any Lc material — pure cheat sheet (confirmed 4/5 years)

- **Risk equation:**  $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact (Asset value)}$ . A **threat agent** exploits a **vulnerability** in an **asset** via an **attack vector**, causing **impact/loss**.
- **Security professions:** Penetration Tester (simulates real attacks under authorization), Cybersecurity Analyst (monitors/responds to incidents), Cybersecurity Architect (designs secure systems), Cybersecurity Auditor (checks compliance/controls), Data Security Analyst (protects data assets/DB security), Network Analyst (secures network infrastructure/traffic).
- **Steganography:** hides the *existence* of a message (e.g. inside an image/audio file) — vs. cryptography, which hides the *content* of a known message.
- **Biometric authentication:** **FAR** (False Accept Rate — impostor wrongly accepted), **FRR** (False Reject Rate — genuine user wrongly rejected), **CER/CrossoverER** (point where FAR=FRR). Evaluation criteria: accuracy, speed, uniqueness, permanence, collectability, user acceptance, circumvention resistance.
- **Wireless network threats:** rogue access points, evil-twin APs, eavesdropping/sniffing, deauthentication attacks, MAC spoofing, weak-encryption (WEP) cracking.
- **Backdoor:** hidden access mechanism that bypasses normal authentication. **Logic bomb:** malicious code that triggers on a specific condition/date. **Trojan horse:** malware disguised as legitimate software — does not self-replicate (unlike a virus).
- **Handshaking:** initial negotiation between two parties to establish session parameters (protocol version, algorithms, keys) before data exchange (e.g. TLS handshake).
- **Message digest:** fixed-length hash of a message (e.g. SHA-256) used to verify integrity — any change to the message changes the digest.

- **Shannon’s atomic operations (confusion & diffusion):** **Confusion** — each ciphertext bit depends on the key in a complex, non-linear way (hides the key-plaintext relationship, e.g. S-boxes). **Diffusion** — changing one plaintext bit changes many ciphertext bits (spreads plaintext statistics, e.g. permutation layers).

## 2024 — Q1(a,b): Symmetric vs Asymmetric Crypto + Handshaking/Digest (5 marks)

### Question — 2024 Q1

- (a) Briefly describe symmetric and asymmetric cryptography with an example. Point out the reason why asymmetric cryptography is useful for e-commerce. [3]
- (b) What is handshaking? Briefly describe how message-digest works. [2]

### Part (a): Symmetric vs Asymmetric Cryptography

#### Answer — 2024 Q1(a)

**Symmetric cryptography:** the *same* key is used for both encryption and decryption. Both parties must share this secret key in advance. *Example:* AES, DES — fast, suited to bulk data encryption.

**Asymmetric cryptography:** uses a mathematically-linked *key pair* — a **public key** (freely shared) and a **private key** (kept secret). Data encrypted with the public key can only be decrypted with the matching private key (and vice-versa for signatures). *Example:* RSA.

**Why asymmetric is useful for e-commerce:**

- **No prior shared secret needed:** a customer can encrypt payment/card details using the merchant's *published* public key — only the merchant's private key can decrypt it, even over an insecure channel (the open internet).
- **Authentication & non-repudiation:** digital signatures (signing with a private key, verified with the public key) let a customer confirm the merchant's identity and prevent either party from later denying a transaction.
- **Secure key exchange:** asymmetric crypto is used in the TLS/SSL handshake to safely establish a temporary symmetric session key, combining the security of asymmetric crypto with the speed of symmetric crypto for the actual data transfer.

### Part (b): Handshaking and Message Digest

#### Answer — 2024 Q1(b)

**Handshaking:** the initial negotiation phase between two communicating parties before real data exchange. Both sides agree on protocol version, supported cryptographic algorithms, and exchange/derive session keys (e.g. the TLS handshake establishes a shared symmetric session key using asymmetric crypto).

**Message digest:** the fixed-length output of a one-way **hash function** (e.g. SHA-256) applied to a message of any length. It acts as a "fingerprint":

- Same input → always the same digest (deterministic).
- Any change to the input — even one bit — produces a completely different digest (used to verify **integrity**).

- Computationally infeasible to find two different messages with the same digest (collision-resistance), or to recover the message from the digest (one-way).

## 2023 — Q2(b,c): Digital Certificates/CA/SSL + Securing a Network from 4 Attack Types (6 marks)

### Question — 2023 Q2

(b) Describe how digital certificates, certificate authorities, and SSL work together to exchange data on the web securely and reliably with an illustrative example. [4]

(c) Explain briefly how to secure a network from: (i) Phishing attack (ii) Denial of service attack (iii) SQL injection attack (iv) Clop ransomware. [2]

(Related, 2023 Q4(c)): Discuss about two atomic operations proposed by Shannon in security. [1]

### Part (b): Digital Certificates, Certificate Authorities, and SSL

#### Answer — 2023 Q2(b)

**Digital certificate:** an electronic document that binds a **public key** to an identity (e.g. a website's domain name), digitally signed by a trusted third party. It contains: subject identity, public key, issuer (CA) name, validity period, and the CA's signature.

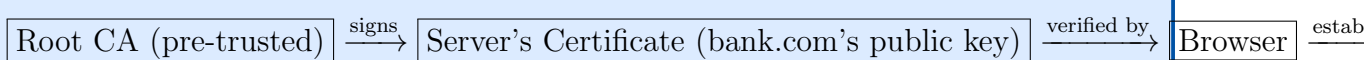
**Certificate Authority (CA):** a trusted third-party organization (e.g. DigiCert, Let's Encrypt) that verifies the identity of an entity (e.g. a website owner) and **signs** its certificate with the CA's own private key, vouching for the binding between identity and public key. Browsers/OSes ship with a built-in list of trusted **root CA** certificates.

**SSL/TLS:** the protocol that uses these certificates to establish an authenticated, encrypted channel between a client (browser) and server.

**How they work together — illustrative example (browser visiting <https://bank.com>):**

1. **Certificate presentation:** the server sends its digital certificate, containing **bank.com's** public key and the CA's signature over that certificate.
2. **Certificate verification:** the browser checks the CA's signature using the CA's public key (already trusted/pre-installed as a root certificate) — confirming the certificate is genuine and **bank.com's** public key is authentic, and checks the domain name and expiry date.
3. **Key exchange (SSL/TLS handshake):** the browser generates a random **session key**, encrypts it with **bank.com's** verified public key, and sends it to the server. Only the server's private key can decrypt it.
4. **Secure data exchange:** both sides now share the session key and use fast **symmetric encryption** (e.g. AES) for the rest of the session — ensuring confidentiality, integrity, and server authenticity (the padlock icon).

**Chain of trust:**



*One-line summary: the CA's signature lets the browser trust the server's public key without ever having met the server before; SSL/TLS then uses that public key to safely agree on a symmetric session key for the actual encrypted exchange.*

### Part (c): Securing a Network from 4 Attack Types

#### Answer — 2023 Q2(c)

| Attack                 | Mitigation                                                                                                                                                               |
|------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| (i) Phishing           | User awareness/training, email filtering & spam detection, multi-factor authentication (so a stolen password alone isn't enough).                                        |
| (ii) Denial of Service | Rate limiting, firewalls/traffic filtering, intrusion detection & prevention systems (IDS/IPS), load balancing, anti-DDoS/CDN services.                                  |
| (iii) SQL Injection    | Input validation/sanitization, parameterized queries (prepared statements), least-privilege database accounts, web application firewall (WAF).                           |
| (iv) Clop ransomware   | Regular <i>offline</i> backups, keep OS/antivirus updated and never disable them, network segmentation to limit spread, employee training against malicious attachments. |

*One-line-per-attack is enough for 0.5 marks each — name the mitigation type, don't write essays.*

### Related (Q4(c)): Shannon's Two Atomic Operations

#### Answer — 2023 Q4(c)

Claude Shannon proposed **confusion** and **diffusion** as the two fundamental operations for secure cipher design:

- **Confusion:** makes the relationship between key and ciphertext as complex/non-linear as possible (e.g. S-box substitution in AES/DES) — hides which key bits affect which ciphertext bits.
- **Diffusion:** spreads the influence of a single plaintext (or key) bit over many ciphertext bits (e.g. permutation/mixing layers) — so statistical patterns in the plaintext are dissipated across the ciphertext.

Together they defeat statistical cryptanalysis (e.g. frequency analysis) — the basis of all modern block ciphers (DES, AES).

**2022 — Q1 (8 marks): Security Vocabulary; Q7(b,c): SQLi/Social Eng + SWIFT****Question — 2022 Q1**

- (a) “Ambiguity is security” — why and how? [2]
- (b) Fill in the blanks with A, B and C in the following with appropriate information/computer-security terms, briefly defining them: “A ..... (C) ..... here is the existence of an individual motivated to profit by stealing an asset and selling it for cash.” [3]
- (c) Write down key roles and responsibilities for the following professions in information/computer security: Penetration tester, Cyber security analyst, Cyber security auditor, Data security analyst, Network analyst, Cyber security architect. [2]
- (d) What is steganography? [1]

**Part (a): “Ambiguity is Security” — Why and How?****Answer — 2022 Q1(a)**

This refers to **security through obscurity**: keeping implementation details, configurations, or system internals *ambiguous/hidden* raises the effort and uncertainty for an attacker — e.g. hiding software version banners, using non-default ports, not publishing network topology, randomizing memory layouts (ASLR).

**How it helps:** an attacker who doesn’t know exactly what they’re attacking must spend more time on reconnaissance, increasing the chance of detection.

**Caveat (Kerckhoffs’s principle):** ambiguity should only be a *supplementary* layer — a system’s core security must not depend on secrecy of its design/algorithm, only on the secrecy of the key. Relying solely on ambiguity is “false security.”

**Part (b): Fill-in-the-Blank — Threat Actor Terminology****Answer — 2022 Q1(b)**

The sentence describes a **Threat Actor** (specifically a financially-motivated one, e.g. a cybercriminal). Core vocabulary to fill A/B/C-style blanks in this family of questions:



| Term                        | Definition                                                                                                                                                                                  |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Asset</b>                | Anything of value to an organization (data, hardware, reputation) that needs protecting.                                                                                                    |
| <b>Threat</b>               | A potential cause of an unwanted, harmful incident.                                                                                                                                         |
| <b>Threat Actor (Agent)</b> | An individual or group that carries out a threat — <i>here</i> , “an individual motivated to profit by stealing an asset and selling it for cash” (a financially-motivated cyber-criminal). |
| <b>Vulnerability</b>        | A weakness that can be exploited by a threat to gain unauthorized access.                                                                                                                   |
| <b>Attack Vector</b>        | The path or means by which an attacker gains access to exploit a vulnerability.                                                                                                             |

*Exam tip: this question family always defines ONE term via a scenario sentence and asks you to name + define 2–3 related terms. Memorize the 5-term chain Asset → Threat → Threat Actor → Vulnerability → Attack Vector → Impact/Risk.*

### Part (c): Security Professions — Roles and Responsibilities

#### Answer — 2022 Q1(c)

| Profession               | Role / Responsibility                                                                                      |
|--------------------------|------------------------------------------------------------------------------------------------------------|
| Penetration Tester       | Simulates real-world attacks (with authorization) to find exploitable vulnerabilities before attackers do. |
| Cyber Security Analyst   | Monitors systems/networks for threats, investigates and responds to security incidents.                    |
| Cyber Security Auditor   | Reviews systems/processes for compliance with security policies, standards, and regulations.               |
| Data Security Analyst    | Focuses on protecting data assets — access controls, encryption, data-loss prevention.                     |
| Network Analyst          | Monitors and secures network infrastructure and traffic, manages firewalls/IDS.                            |
| Cyber Security Architect | Designs the overall security structure/strategy of systems and networks.                                   |

**Part (d): Steganography****Answer — 2022 Q1(d)**

**Steganography** is the practice of hiding the *existence* of a secret message within an ordinary-looking carrier (e.g. embedding text inside an image, audio, or video file) so that only sender and receiver know a hidden message exists.

**Contrast with cryptography:** cryptography hides the *content* of a message that is openly known to exist (visible ciphertext); steganography hides the *fact that a message exists at all*. The two are complementary and often combined (encrypt, then hide).

**Part Q7(b): SQL Injection and Social Engineering — Short Notes****Question — 2022 Q7(b)**

Write short notes on: SQL injection and social engineering.

[≈3]

**Answer — 2022 Q7(b)**

**SQL Injection:** an attack where malicious SQL code is inserted into application input fields (e.g. login forms) and executed by the backend database — can bypass authentication, read/modify/delete data, or even gain control of the database server. Mitigation: parameterized queries, input validation, least-privilege DB accounts.

**Social Engineering:** manipulating people (not systems) into divulging confidential information or performing actions that compromise security — exploits trust, urgency, or authority rather than technical flaws. Phishing is its most common form. Mitigation: security-awareness training, verification procedures for sensitive requests.

**Part Q7(c): SWIFT Banking Network Pentest Scenario****Question — 2022 Q7(c)**

SWIFT is a worldwide network used by banks to send and receive financial transaction messages. ... You've been hired to do a penetration test of a bank's SWIFT gateway. What should your goal be? That is, what concrete, verifiable result would prove that you have successfully hacked your client's SWIFT gateway? ... Of course you do not want to damage the SWIFT gateway in any way, and especially not do anything that would leave it open to other attackers. What steps would you take to ensure that there was no damage? [≈4]

**Answer — 2022 Q7(c)**

**Goal-setting (proving success without real fraud):** demonstrate the *capability* to send/alter a SWIFT message or access restricted SWIFT infrastructure — e.g. show you could have injected a fraudulent transaction message into the queue, or

accessed credentials/keys used to authorize SWIFT transfers — **without actually submitting it**. A concrete, verifiable proof: a screenshot/log showing access to the SWIFT messaging interface or successful privilege escalation to a SWIFT-operator account, captured non-destructively.

**Non-damaging steps (rules of engagement):**

1. Agree a written scope & authorization (rules of engagement) with the bank *before* starting — define exactly what's in/out of scope.
2. Use a **test/staging environment** where possible instead of live production SWIFT systems.
3. Avoid actually executing fraudulent transactions — stop at the "proof of access/capability" stage.
4. Take backups/snapshots before any active exploitation; have a rollback plan.
5. Coordinate timing with the bank's operations team to avoid disrupting live banking hours.
6. Document everything and report findings responsibly, then assist with remediation.

*Exam tip: graders look for the phrase "no damage to production / live systems" and "prior written authorization" — always include these two ideas.*

## 2021 — A-1: Risk Equation, Biometrics, Wireless (8.75 marks); B-4(a,d): Ransomware/Social Eng + Backdoor/Logic Bomb/Trojan (3.75 marks)

### Question — 2021 A-1 and B-4

#### A-1.

- (a) Derive a risk equation depending on threat agent, probability of attack, and expected loss. Draw a related model. [4.75]
- (b) How do physical and behavioural biometrics fail for authentication? How would you evaluate biometrics using standard criteria? [3]
- (c) Remark on the threats in wireless security. [1]

#### B-4.

- (a) How would you differentiate between ransomware and social engineering? [2]
- (d) Describe backdoor, logic bomb, and Trojan horse. [1.75]

### Part A-1(a): Risk Equation and Model

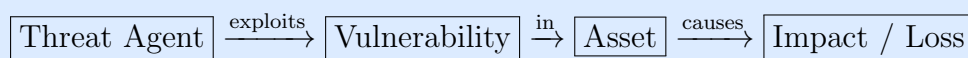
#### Answer — 2021 A-1(a)

##### Risk equation:

$$\text{Risk} = \text{Threat Agent} \times \text{Probability of Attack} \times \text{Expected Loss (Impact)}$$

i.e.  $\text{Risk} \propto (\text{likelihood of a threat agent attacking}) \times (\text{magnitude of loss if it succeeds})$ . Equivalently, the general security-risk form:  $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Asset Value}$ .

##### Model (chain of causation):



A higher probability of attack (more attractive/exposed asset) or a higher expected loss (more valuable/critical asset) both increase overall **Risk**. Risk-reduction strategies target each factor: reduce vulnerability (patching), reduce probability (deterrence/monitoring), or reduce impact (backups, segmentation, insurance).

### Part A-1(b): Biometric Authentication — Failure Modes and Evaluation

#### Answer — 2021 A-1(b)

##### How biometrics fail:

- **False Accept (Type II error / FAR):** an impostor is incorrectly accepted as a legitimate user.

- **False Reject (Type I error / FRR):** a legitimate user is incorrectly rejected.
- **Physical biometrics** (fingerprint, iris, face) can fail due to injury, aging, sensor noise, lighting, or spoofing (fake fingerprints/photos).
- **Behavioural biometrics** (gait, typing rhythm, voice) can fail due to natural variability (mood, illness, environment) and are easier to mimic over time.

**Evaluation criteria (standard):**

| Criterion              | Meaning                                                                  |
|------------------------|--------------------------------------------------------------------------|
| Accuracy (FAR/FRR/CER) | Lower error rates = better; CER (crossover error rate) is where FAR=FRR. |
| Uniqueness             | How distinct the trait is across individuals.                            |
| Permanence             | How stable the trait remains over time.                                  |
| Collectability         | How easily/cheaply the trait can be measured.                            |
| Performance/Speed      | Time taken to capture and match.                                         |
| Acceptability          | How willing users are to use it.                                         |
| Circumvention          | How hard the trait is to spoof/forgo.                                    |

**Part A-1(c): Threats in Wireless Security**

**Answer — 2021 A-1(c)**

- **Eavesdropping/sniffing:** intercepting wireless traffic over the air.
- **Rogue access points / Evil twin:** fake APs mimicking legitimate networks to capture credentials/traffic.
- **Deauthentication attacks:** forcibly disconnecting clients to capture handshakes or force reconnection to a rogue AP.
- **Weak encryption cracking:** breaking outdated protocols (WEP) or weak WPA passwords.
- **MAC spoofing:** impersonating an authorized device's MAC address to bypass MAC-filtering.

**Part B-4(a): Ransomware vs Social Engineering**

## Answer — 2021 B-4(a)

|              | Ransomware                                                                                                               | Social Engineering                                                                                                                   |
|--------------|--------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| What it is   | Malicious <i>software</i> that encrypts a victim's files/systems and demands payment for the decryption key.             | A <i>technique</i> of psychologically manipulating people into revealing information or performing actions that compromise security. |
| Mechanism    | Technical — exploits software vulnerabilities or runs malicious code once executed.                                      | Human — exploits trust, fear, urgency, or authority.                                                                                 |
| Relationship | Often <i>delivered via</i> social engineering (e.g. a phishing email tricks a user into running the ransomware payload). | Is frequently the <i>delivery vector</i> for malware including ransomware.                                                           |

**One-line distinction:** ransomware is *malware* (a technical artifact); social engineering is a *manipulation technique* (a human-targeted method) — the two are often combined, with social engineering as the infection vector for ransomware.

## Part B-4(d): Backdoor, Logic Bomb, Trojan Horse

## Answer — 2021 B-4(d)

- **Backdoor:** a hidden method of bypassing normal authentication/access controls to gain (often persistent) unauthorized access to a system — may be intentionally built in by a developer or installed by malware.
- **Logic Bomb:** malicious code that lies dormant until triggered by a specific condition (a date, an event, a user action) — e.g. code that wipes files if a disgruntled employee's account is deleted.
- **Trojan Horse:** malware disguised as, or bundled with, legitimate/desirable software. Unlike a virus, it does **not self-replicate** — it relies on the user voluntarily installing/running it.

## Exam Strategy Summary

### High-Yield Checklist for Security Fundamentals & Attacks (4/5 years, 2–9 marks)

1. **Attack short-notes** (Lc#1, pp.2-17): DoS vs DDoS, Phishing, SQL Injection, Ransomware (Clop/WannaCry), Rogue security software — always know a 1-2 sentence definition AND a mitigation for each.
2. **Threat-actor vocabulary chain:** Asset → Threat → Threat Actor → Vulnerability → Attack Vector → Risk/Impact. Practice filling these into a scenario sentence (2022 Q1b style).
3. **Security professions:** 6 roles (pentester, analyst, auditor, architect, data security analyst, network analyst) — one sentence each.
4. **Steganography** vs cryptography — one sentence each, state the difference explicitly.
5. **Biometrics:** FAR/FRR/CER + 4-5 evaluation criteria; physical vs behavioural failure modes.
6. **Wireless threats:** 4-5 named attacks (rogue AP, evil twin, deauth, MAC spoofing, WEP cracking).
7. **Malware trio:** backdoor (hidden access) vs logic bomb (condition-triggered) vs Trojan horse (disguise, no self-replication) — and ransomware vs social engineering (malware vs human-manipulation technique).
8. **Risk equation:**  $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$ , plus the causal-chain diagram.
9. **Handshaking + message digest**, and **Shannon's confusion/diffusion** — one-liners, low effort, recurring.
10. **SWIFT pentest essay** (if it recurs): always say "prior written authorization" + "no damage to production".